

コーディングエージェントの セキュリティ対策

Claude Codeの権限設計と実行環境の比較

目的と構成

Claude Codeを動かす5つの構成について、どの被害を防げるか、どの設定が必要かを比較する。

1. 仮定：攻撃者に可能な操作と、信頼する仕組み
2. 要求：防ぎたい被害と、求める防御の強さ
3. 仕様・実測：各構成が設ける制限と、実験で確認した挙動
4. 評価：その制限が、想定した攻撃を止められるか

想定する誤操作と攻撃

エージェントと、その実行するプログラムについて、次の動作を仮定する。

種類	動作の例
誤操作	利用者の指示に従おうとして、削除対象のパスを間違える
攻撃	悪意ある指示やプログラムにより、攻撃者のtokenで情報を送る。制限の回避も試みる

隔離機構、制限を設定する管理者側の仕組み、承認システム自体への侵害は、この比較の対象外とする。

防ぎたい被害と要求水準

この比較では、開発に必要な編集や通信を許可し、次の防御を要求する。

被害	求める防御
許可していない相手への情報流出	攻撃でも阻止する
編集を許可しないホストファイル・既存設定の変更	攻撃でも阻止する。作業フォルダ内のホスト用.git/configやhookも対象
本番の変更、公開、権限の変更	攻撃でも阻止する
編集を許可したソース・履歴・記憶データの破壊や改変	誤操作による被害を減らす。悪意ある変更は残るリスクとして扱う
許可した相手への秘密の誤送信、ファイルへの誤保存	誤操作による被害を減らす

比較条件

許可方針と設定を以下のように定め、方針に反する操作を止められるかを評価する。

区分	比較に使う方針・設定・仮定
許可方針	通信先はAnthropic API、GitHub、開発用の業務APIに限る
許可方針	GitHubで読み書きしてよいのは、自組織の指定した非公開repoだけ
設定	利用者のtokenの権限を必要最小限にする。本番の認証情報は渡さず、CIの権限と承認設定も制限する
設定	Claude Codeが実行しようとするshellコマンドをauto modeのAIが審査する。 WebSearchツールは外す
APIの仮定	業務APIは自組織の開発環境専用で、第三者への保存・転送機能がない架空のAPIとする

AIの操作審査は、誤操作による被害を減らす対策として評価する。

GitHubの接続許可と書込み先

社内repoにだけ情報を渡したい場合の例。通信制限ではapi.github.comへの接続を許可し、tokenやrepoは検査しない。

エージェント内のプログラムが、次のtokenを使えると仮定する。

書込み先	接続先のホスト名	使えるtoken	通信の可否
社内のrepo	api.github.com	社内repoへの書込み権限を持つ利用者のtoken	通る
攻撃者のrepo	api.github.com	そのrepoへの書込み権限を持つ、攻撃者が持ち込んだtoken	通る

比較する実行環境

同じClaude Codeを、次の構成で動かす。srtとnasは、隔離環境で起動するためのツール。

構成	隔離する範囲	通信の制限
Claude Code内蔵 sandbox	Bashと、その子プロセス	ホスト名で制限
srt	Claude Code本体を含む全プロセス	ホスト名で制限
Dev Container	コンテナ内の全プロセス	コンテナ内で接続先IPを制限
nas	コンテナ内の全プロセス	コンテナ外のproxyで宛先・操作を検査
Docker Sandbox	仮想マシン内の全プロセス	VM外でホスト名を制限

Docker Sandboxの認証処理

実測対象はv0.45。GitHubのアカウント情報を取得するAPIに、同じ無効なtokenを送った。

通常のproxyは、送信時にtokenをホストに保存した認証情報へ置き換える。

経路	観測した応答
通常のproxy経由	200成功。ホスト側のアカウント情報が返った
認証proxyを使わない経路	401 Bad credentials。通信は届き、GitHubが無効なtokenを拒否した

proxyを使わない経路では、証明書とログでも認証情報の置換を通らないことを確認した。

Docker Sandboxの評価

接続先のホスト名を制限し、proxyで認証情報を置き換える構成を評価する。

1. **仮定**：攻撃者は、自分のrepoに書き込めるtokenを持ち込める。
2. **実測**：プログラムが指定したtokenを、置き換えずにGitHubへ送れる経路があった。
3. **判断**：その経路で有効なtokenを使われると、書込み先のrepoを制限できないと評価する。
未許可repoへの流出を阻止する要求は満たさない。
4. **未検証**：有効な攻撃者tokenでの書込みと、情報流出の完遂。

各構成の保護設定

構成	比較に用いた設定	制限を評価する根拠
内蔵sandbox	Bashを隔離。WebFetch・MCP・隔離外での実行を無効化	設定：Claude Code本体のホスト書き込みを、一律には禁止していない
srt	Claude Code全体の書き込みを制限。Git設定・hook・.claudeを保護	実測：0.0.77で、認証情報を置き換えずに許可先へ送れる経路を確認
Dev Container	コンテナ内で接続先IPを制限。作業フォルダをホストと共有	仕様・設定：DNSで情報を送れ、同じIP上の別ホスト名にも接続可能。共有する設定は書換え可能
nas	GitHubのtoken・repo・操作をproxyで制限。AnthropicのFiles APIは拒否	仕様：範囲外は承認まで停止。業務APIは、比較条件の架空の仕様を前提とする
Docker Sandbox	ホストrepoは読取り専用。VM内のコピーを編集	実測：ホスト名による通信制限と、認証情報の置換を通らない経路を確認

比較評価

仕様・設定と一部の実測に基づく評価。全項目を実測した表ではない。

◎ 攻撃による操作も、拒否または人間の承認待ちで止める。

○ 誤操作による被害を減らす。攻撃では回避される場合がある。

防御対象・要求水準は◎	内蔵sandbox	srt	Dev Container	nas	Docker Sandbox
接続を許可していない相手への 情報流出	◎	◎	○	◎	◎
許可サービス内の未許可repo 等への情報流出	○	○	○	◎	○
編集を許可しないホストファイ ル・既存設定の変更	○	◎	○	◎※	◎

※ nasは、既存設定とhookを保護する配置・設定が条件。

nasの利用条件

対象	利用条件と残るリスク
GitHub	proxyがrepo・操作を検査し、tokenを利用者のものへ置換。範囲外は人間の承認まで止める
Anthropic・業務API	Anthropicのファイル保存APIは拒否。業務APIは、自組織の開発環境だけにアクセスできる仕様を仮定
ホストの設定	既存設定・hook・参照先と、作業フォルダの.claudeを保護する
作業内容・履歴	エージェントが書換え可能。履歴・記憶データはホストと共有し、次の実行で再利用する
運用	利用者がAPIごとの許可設定を保守する。承認者の判断精度や確認負担は未実測

導入時に確認する項目

1. エージェントに編集させるファイルと、書込みを禁止する設定
2. 情報を送ってよいサービス・アカウント・repo
3. 承認なしで取得してよい情報源と、そこへ投稿できる人
4. 本番操作につながるCIの権限と、承認が必要な操作
5. 変更内容をレビューする人、復旧方法、設定を保守する人

付録・秘密情報を隠す設定

利用者が、各構成で使える機能に合わせて読取禁止や値の置換を設定する。

作業での使い方	用意する対策
作業で使わない秘密情報	ファイルを共有から外すか、読取りを禁止する
HTTP認証に本物のtokenが必要	対応するproxyで、ダミーtokenを送信時に本物へ置き換える
設定ファイルは必要だが、本物の値は不要	マスク機能でファイルの形を残し、秘密の値だけをダミーにする
ツール出力に秘密が含まれる	出力のマスク処理で、モデルに渡す前に秘密の値を伏せる

付録・情報の取得元の制限

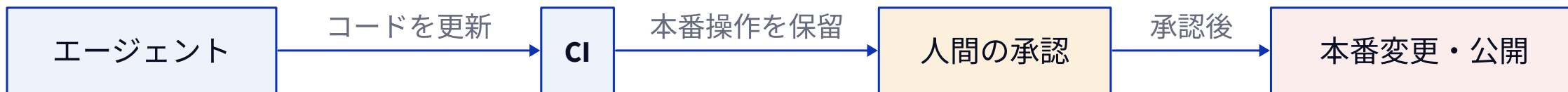
自動取得を許すrepoは、公開範囲と投稿者を確認して選ぶ。取得元を絞っても攻撃は想定し、被害への防御は別に評価する。

構成	取得元を審査・制限する仕組み	評価
5構成共通	auto modeのAIに、許可したrepo以外の取得を拒否するルールを与える	○
nasの追加制限	GitHubのREST API・Git fetch・許可したGraphQL queryをproxyで検査。範囲外は人間の承認まで止める	◎は記載したGitHub経路に限る

付録・CIからの本番操作

CIの権限と承認設定は5構成に共通する導入条件とし、比較表では採点しない。

CIに本番用の権限を渡さないか、本番操作の前に人間の承認を必須にする。承認設定は、エージェントが編集できるworkflowの外で管理する。



付録・評価一覧

比較条件を満たす設定に対する評価。◎は攻撃の阻止、○は誤操作などの被害の低減。

要求	必要水準	内蔵 sandbox	srt	Dev Container	nas	Docker Sandbox
A1a 未許可の接続先への流出	◎	◎	◎	○	◎	◎
A1b 許可サービス内の未許可repo等への流出	◎	○	○	○	◎	○
B2a ホストファイル・既存設定の変更	◎	○	◎	○	◎※	◎
A2 許可した相手への秘密の誤送信	○以上	○	○	○	○	○
A3 秘密の誤保存	○以上	○	○	○	○	○
B2b 作業ファイル・履歴の破壊や改変	○以上	○	○	○	○	○
P1 未許可の情報源からの自動取得	○以上	○	○	○	◎†	○

※ 既存設定・hookの保護が条件。 † 15枚目に記載したGitHubの経路。 A2・A3・B2bは誤操作への評価。

付録・出典と検証範囲

Docker Sandboxの実測対象はv0.45。v3のHTTP制限は未実測。

根拠の種類	資料・対象
要求・判断	脅威モデル ：要求水準と各方式の評価理由
設定	構成ごとの設定例 ：共通条件と保護対象
実測	srt 0.0.77 ：許可先へ認証情報を置き換えずに通信できる経路を確認
実測	sbx v0.45 ：認証情報の置換を通らず、無効なtokenでGitHubから401が返る経路を確認
実測	sbx v0.45 ：ホスト名に応じた接続の拒否と、接続先IPの再解決を確認